

Segurança em Sistemas de Informação

Ronierison. Maciel

FICR

Fevereiro de 2026



Nome: Roni

Formação: Mestre em Ciência da Computação

Ocupação: Pesquisador, Professor e Escovador de bits

Hobbies: Jogar cartas, ficar com a família

Interesses: Carros, DevSec, DS e ML

Email: ronierison.maciел@p.ficr.edu.br

GitHub: <https://github.com/0x03c1>

- 1 Introdução
- 2 Conceitos fundamentais de segurança da informação
- 3 Identificação de ameaças e vulnerabilidades em sistemas computacionais
- 4 Criptografia e Autenticação: Conceitos e Aplicações
- 5 Segurança em Redes e Protocolos de Comunicação Segura
- 6 Análise de Ataques Cibernéticos e Medidas de Mitigação
- 7 Segurança em Ambientes de Computação em Nuvem e Desafios Atuais
- 8 Avaliação – Unidade I
- 9 Ferramentas para auditoria e conformidade em segurança digital
- 10 Desenvolvimento e implementação de políticas de segurança da informação
- 11 Simulação prática de um ataque cibernético e resposta a incidentes
- 12 Investigação forense digital: princípios e ferramentas
- 13 Monitoramento contínuo e gestão de riscos em ambientes corporativos
- 14 Pentests e análise de vulnerabilidades
- 15 Avaliação – Unidade II

Se você precisasse proteger sua casa contra invasores, qual dessas medidas adotaria primeiro?

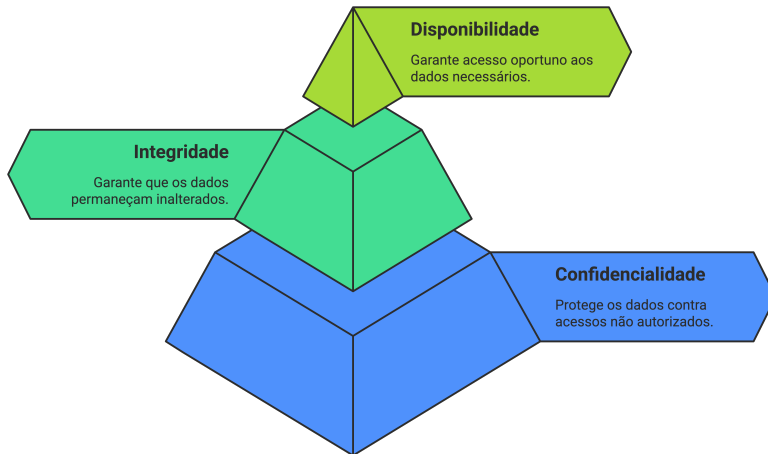
Elementos de uma Casa Protegida



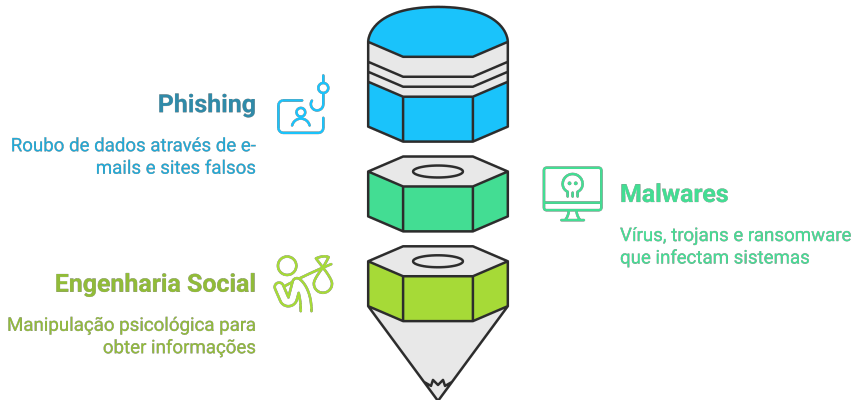
Agora, conectando essa ideia ao mundo digital:

- Se sua senha vazasse hoje, quais seriam as consequências para sua vida?
 - Quem já teve a senha vazada e quais problemas isso acarretou?
 - Se ainda não teve a senha vazada, o que está fazendo para se proteger?

Pirâmide de Segurança da Tríade CIA



Visão Geral das Ameaças de Segurança Cibernética



A seguir, são apresentados exemplos práticos de ataques reais envolvendo malware, ransomware, phishing e engenharia social, juntamente com seus respectivos impactos.

Em setembro de 2025, a rede de educação infantil Kido International foi vítima de um ataque de ransomware que comprometeu dados de aproximadamente 8.000 crianças e funcionários de várias creches no Reino Unido. Os criminosos usaram uma tática de dupla extorsão (encrypt + ameaça de vazamento), expondo nomes, fotos, datas de nascimento, endereços e contatos gerando preocupação pela sensibilidade dos dados envolvidos.

- Fonte: Wikipedia / Kido International cyberattack

Em julho de 2025, a cidade de Saint Paul (Minnesota, EUA) sofreu um ataque cibernético deliberado que paralisou sistemas públicos desde redes internas até portais de pagamento online. A resposta foi tão crítica que as autoridades mobilizaram a Guarda Nacional de Minnesota para conter a ameaça. O grupo reivindicou o ataque e publicou 43 GB de dados roubados, após a cidade se recusar a pagar o resgate.

- Fonte: TecMundo / 2025 St. Paul cyberattack

VolkLocker é um ransomware identificado em 2025 vinculado ao grupo pró-russo CyberVolk. Distribuído por meio de um modelo de ransomware-as-a-service (RaaS), ele criptografa sistemas Windows e Linux com AES-256 GCM e adiciona extensões maliciosas aos arquivos. Pesquisadores notaram uma falha de design uma chave mestra embutida que permitiu recuperação gratuita em alguns casos, evidenciando tanto a sofisticação quanto os erros de implementação desse tipo de ameaça moderna.

- Fonte: Wikipedia / VolkLocker

Um relatório recente revelou uma campanha de malware alimentada por IA que visava especificamente desenvolvedores de blockchain e cripto. Os atacantes, associados ao grupo norte-coreano KONNI, enviaram e-mails convincentes com payloads PowerShell que instalavam backdoors aproveitando técnicas de phishing adaptadas por IA para enganar profissionais de TI e acessar sistemas de nuvem, APIs e repositórios de código.

- Fonte: TechRadar

Esses ataques resultam em:

- Perdas financeiras significativas
- Comprometimento de dados sensíveis
- Interrupção de operações
- Danos à reputação das organizações afetadas

Além disso, evidenciam a importância de medidas de segurança cibernética robustas e da conscientização contínua dos usuários para prevenir futuras ameaças.

Como se proteger?

- Usar senhas fortes e autenticação de dois fatores.
- Evitar clicar em links suspeitos ou baixar arquivos desconhecidos.
- Atualizar softwares e sistemas regularmente.
- Ser cuidadoso com informações compartilhadas online.

Atividade: Criar uma senha forte em 10 segundos.

Desafio: Qual mudança fará na sua segurança digital após esta aula?

Conclusão: Segurança da Informação é essencial para todos que usam tecnologia!

- Analisar cenários fictícios de ataques cibernéticos.
- Identificar o tipo de ameaça envolvida.
- Propor formas de prevenção ou mitigação.

- Grupos de 3 a 5 pessoas.
- Cada grupo recebe um cenário para análise e discussão.

Situação:

- Recebimento de e-mail solicitando confirmação de dados bancários através de um link.

Ações sugeridas:

- 1 Descrição da situação
- 2 Ação preventiva
- 3 Verificação adicional
- 4 Procedimento recomendado

Situação:

- Após baixar um programa de um site desconhecido, todos os arquivos do computador são criptografados, com exigência de pagamento para recuperação.

Ações sugeridas:

- 1 Descrição da situação
- 2 Medida preventiva
- 3 Ação corretiva
- 4 Ferramenta de proteção

Situação:

- Recebimento de mensagem de um perfil falso de amigo no Instagram solicitando dinheiro devido a uma emergência.

Ações sugeridas:

- 1 Descrição da situação
- 2 Método de verificação
- 3 Ação preventiva
- 4 Medida de segurança

Situação:

- Conexão a uma rede Wi-Fi pública sem senha resulta em acesso não autorizado à conta bancária.

Ações sugeridas:

- 1 Descrição da situação
- 2 Ação preventiva
- 3 Ferramenta de proteção
- 4 Procedimento recomendado

- Cada grupo apresenta suas conclusões sobre o cenário analisado em até 5 minutos.

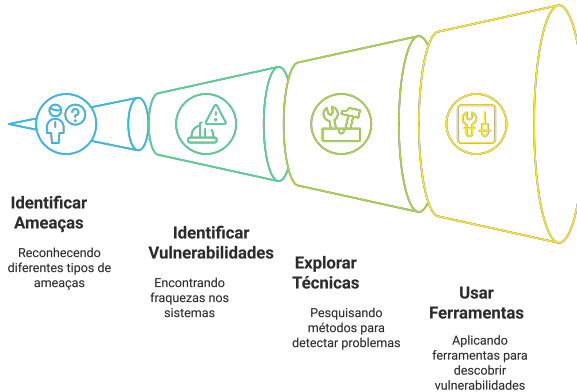


Teste seus conhecimentos!

- Reflexão sobre a prevalência das ameaças cibernéticas no cotidiano.
- Importância da conscientização e adoção de medidas preventivas para proteger dados e informações pessoais.

- Compreender ameaças, vulnerabilidades e riscos em sistemas computacionais.
- Identificar diferentes tipos de ameaças e vulnerabilidades.
- Explorar técnicas e ferramentas para detectar vulnerabilidades.

Processo de Identificação de Vulnerabilidades



- **Ameaça:** Evento que pode comprometer um sistema.
- **Vulnerabilidade:** Falha ou fraqueza explorável por uma ameaça.
- **Risco:** Probabilidade de uma vulnerabilidade ser explorada e seu impacto.

Conceitos de Segurança



- Malware (Vírus, Trojans, Worms, Ransomware)
- Phishing e Engenharia Social
- Ataques de força bruta e vazamento de credenciais
- Ataques DDoS (Negação de Serviço)
- Exploração de vulnerabilidades web (SQL Injection, XSS, CSRF)

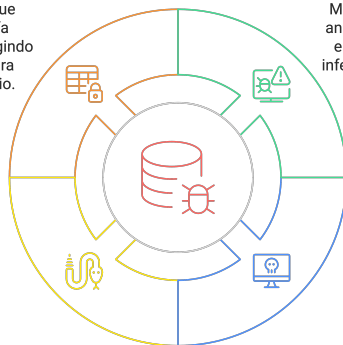
Tipos de Malware

Ransomware

Malware que criptografa arquivos, exigindo resgate para desbloqueio.

Vírus

Malware que se anexa a arquivos e se replica ao infectar sistemas.



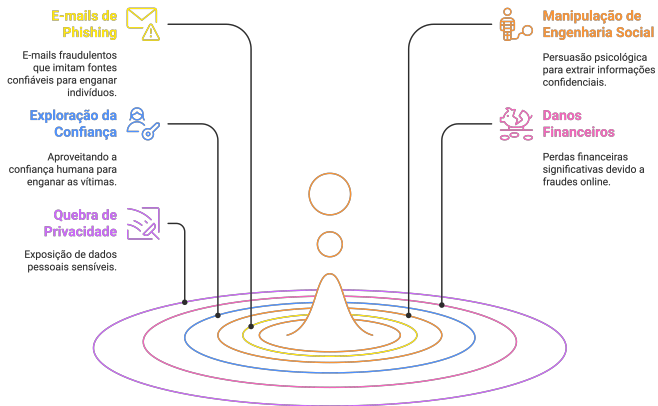
Worms

Malware
autônomo que se
espalha através
de redes, sem
intervenção do
usuário.

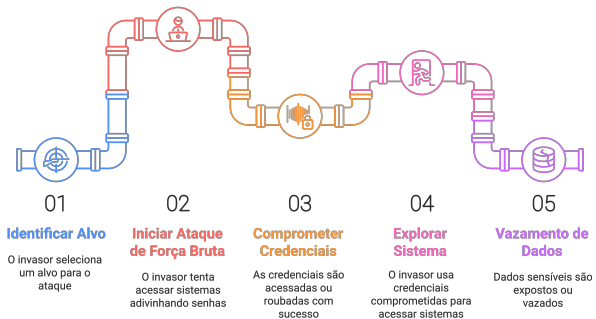
Trojans

Software
malicioso
disfarçado de
legítimo,
enganando
usuários para
instalação.

Entendendo Phishing e Engenharia Social



Sequência de Ataque Cibernético



Sequência de Ataque DDoS



Vulnerabilidades Web



Injeção de SQL

Uma técnica que explora vulnerabilidades na camada de banco de dados de uma aplicação web.



XSS

Uma vulnerabilidade de segurança que permite que atacantes injetem scripts maliciosos em páginas web.



CSRF

Um tipo de ataque que engana o usuário para executar ações indesejadas em um site diferente.

Phishing:

- E-mail falso solicitando dados bancários.
- Link malicioso para roubo de credenciais.

Prevenção:

- Não clicar em links suspeitos.
- Verificar remetente e origem das mensagens.

- Erros de configuração em servidores
- Senhas fracas ou reutilizadas
- Falta de atualizações de software
- Falta de controle de acessos
- Desenvolvimento inseguro de software

Objetivo: Descobrir vulnerabilidades básicas.

Dinâmica:

- Identificar vulnerabilidades como injeção SQL ou XSS.
- Discutir possíveis ataques e formas de mitigação.

Caso real: Vazamento de dados do Facebook, Equifax, Yahoo.

Discussão:

- Como a falha ocorreu?
- Qual o impacto para usuários e empresa?
- Como prevenir ataques semelhantes?

Objetivo: Identificar vulnerabilidades em um ambiente fictício.

Dinâmica:

- Os alunos assumem o papel de auditores.
- Analisam uma empresa com falhas de segurança.
- Propõem soluções para corrigir as vulnerabilidades.

- Qual vulnerabilidade acham mais perigosa?
- Como se proteger dela?

Agora que entendemos a importância das políticas de segurança, vamos explorar os principais componentes que garantem sua eficácia.

1. Controle de Acesso:

- Uso de autenticação forte (MFA).
- Privilégios mínimos para usuários.

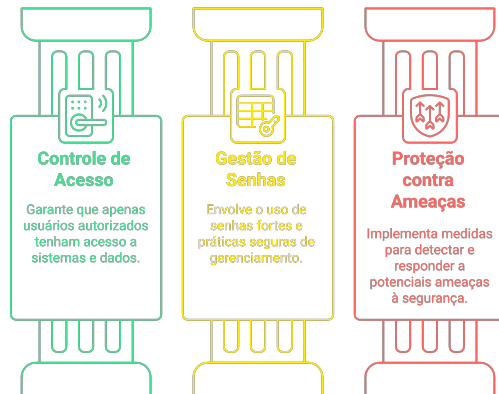
2. Gestão de Senhas:

- Senhas complexas e renovação periódica.
- Armazenamento seguro (hash + salt).

3. Proteção contra Ameaças:

- Firewalls, IDS/IPS e antivírus.
- Monitoramento e resposta a incidentes.

Elementos Essenciais para uma Política de Segurança Eficaz



Principais Normas:

- **LGPD** (Lei Geral de Proteção de Dados).
- **ISO 27001** (Gestão de Segurança da Informação).
- **NIST** (Padrões de segurança recomendados nos EUA).

Objetivo: Garantir que a empresa atue dentro das boas práticas legais e técnicas para proteção de dados.

Estrutura de Conformidade e Segurança de Dados



Caso Real: Vazamento de Dados

Cenário: Uma empresa de e-commerce teve 1 milhão de registros de clientes vazados devido à falta de autenticação forte.

Impacto:

- Além das multas impostas pela LGPD, a empresa enfrentou um declínio na confiança dos clientes, resultando na queda de vendas e na necessidade de reformular suas práticas de segurança.

Lições Aprendidas:

- Implementação de autenticação multifator.
- Criação de uma equipe de resposta a incidentes.

Desafio: Criando uma Política de Segurança

Cenário: Imagine que sua empresa acaba de sofrer um vazamento de dados. Quais medidas de segurança poderiam ter evitado essa situação?

Passos:

- Definir regras para controle de acesso.
- Estabelecer diretrizes para senhas.
- Criar um plano de resposta a incidentes.

Entrega: Apresentação em grupo com os principais pontos da política elaborada.

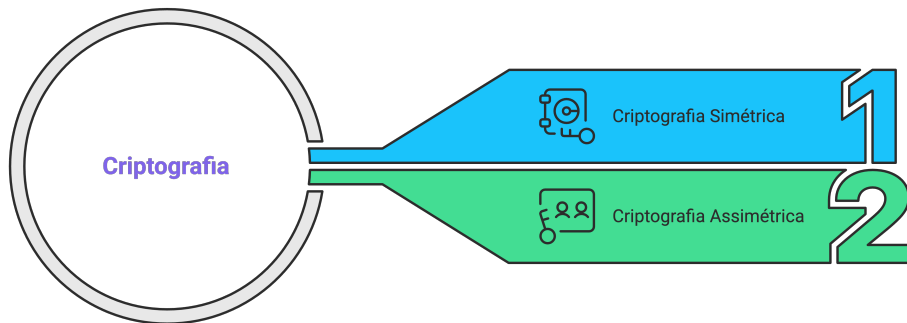
Resumo dos pontos abordados:

- O que são políticas de segurança e por que são essenciais.
- Principais componentes e normas regulatórias.
- Boas práticas e casos reais.
- Atividade prática para consolidar o aprendizado.

Pergunta final: "Se você fosse o responsável pela segurança da sua empresa, o que mudaria a partir de hoje?"

- Compreender os conceitos fundamentais de criptografia e autenticação.
- Explicar as diferenças entre criptografia simétrica e assimétrica.
- Demonstrar a importância da autenticação multifator (MFA).
- Aplicar conceitos aprendidos em atividades práticas.

Explorando os Tipos de Criptografia



O que é criptografia? Técnica usada para proteger informações, transformando dados em um formato seguro contra acessos não autorizados.

Principais tipos:

- **Simétrica:** Usa a mesma chave para criptografar e descriptografar (AES, DES).
- **Assimétrica:** Utiliza duas chaves: uma pública e uma privada (RSA, ECC).

Reflexão: *"Como você garantiria que só o destinatário certo pudesse ler uma mensagem confidencial?"*

Tipos de Criptografia e Seus Usos

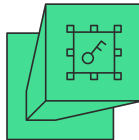
ECC

ECC oferece eficiência em criptografia de uso geral.



AES

AES é ideal para proteção específica de dados sensíveis.



DES

DES é adequado para aplicações gerais de criptografia.



RSA

RSA é usado para segurança específica em comunicações digitais.



Definição: Processo para verificar a identidade de um usuário antes de conceder acesso a um sistema.

Principais Métodos:

- **Senhas:** Método mais comum, mas frequentemente vulnerável.
- **Autenticação Biométrica:** Impressão digital, reconhecimento facial.
- **Autenticação Multifator (MFA):** Combinação de múltiplos métodos para maior segurança.

Exemplo: *"Por que aplicativos como WhatsApp Web exigem autenticação com QR Code?"*

- **AES:**

- Usado em HTTPS, VPNs, discos criptografados e backups.
- Protege grandes volumes de dados com alto desempenho.

- **RSA:**

- Presente em certificados digitais, login seguro e TLS.
- Usado para troca segura de chaves.

- **ECC:**

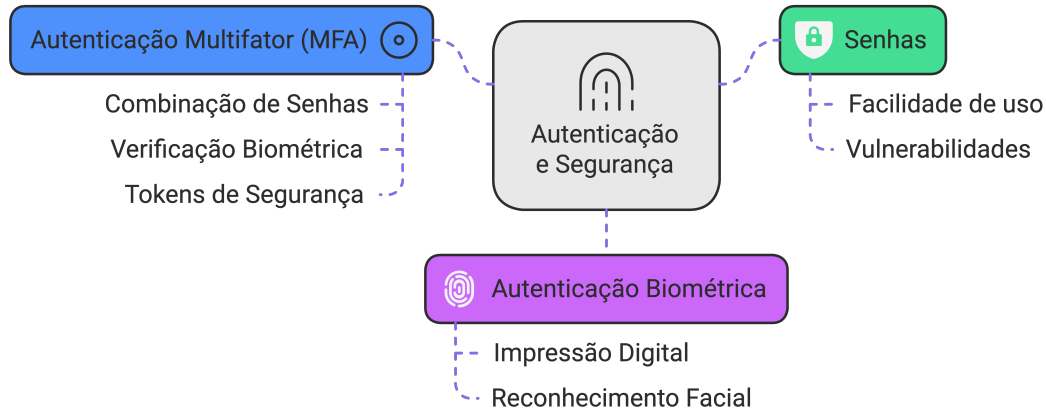
- Usado em dispositivos móveis, IoT e sistemas modernos.
- Oferece alta segurança com menor consumo de recursos.

- **DES (Obsoleto):**

- Chave curta (56 bits), vulnerável a ataques por força bruta.
- Já foi quebrado na prática e não atende padrões atuais.

Reflexão: *"Que riscos uma empresa corre ao usar algoritmos obsoletos em seus sistemas?"*

Autenticação e Segurança: Métodos e Aplicações



Desafio:

- Cada aluno cria uma mensagem e a cifra usando a Cifra de César (deslocamento de 3 letras).
- O parceiro recebe a mensagem criptografada e tenta decifrar.

Objetivo: Demonstrar o funcionamento da criptografia básica e sua aplicação prática.

O que é CyberChef? Ferramenta online que permite testar criptografia e outras transformações de dados.

Atividade:

- Acessar o site do CyberChef.
- Aplicar criptografia AES a um texto.
- Descriptografar usando a chave correta.

Reflexão: *"Como garantir que apenas a pessoa autorizada consiga decifrar a mensagem?"*

Desafio: Identificando Senhas Fracas

- Os alunos recebem um conjunto de senhas vulneráveis.
- Tentam descobrir quais são mais fáceis de serem quebradas.

Discussão:

- Por que senhas como "123456" são inseguras?
- Como o MFA pode prevenir acessos não autorizados?

Principais aprendizados:

- A criptografia protege dados e comunicações.
- Métodos de autenticação forte impedem acessos não autorizados.
- Senhas fracas representam um risco significativo para a segurança.
- O uso de MFA aumenta a proteção de sistemas e contas.

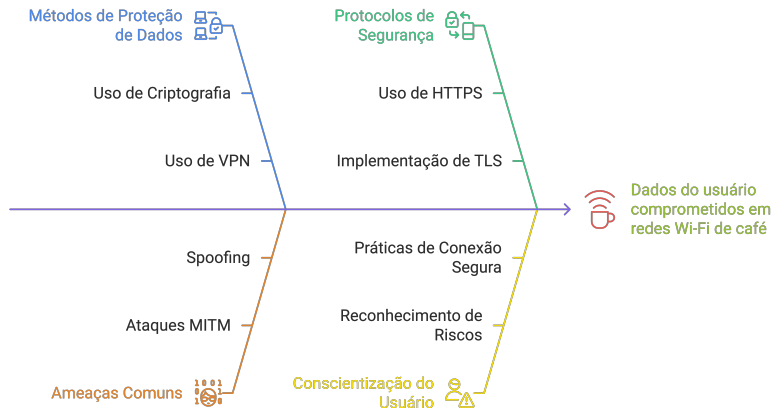
Pergunta Final: *"Se você fosse projetar a segurança de um sistema bancário, quais tecnologias adotaria?"*

Pesquisa:

- Encontre um caso real de vazamento de dados causado por falhas na criptografia ou autenticação fraca.
- Explique como o problema poderia ter sido evitado.

- Compreender os fundamentos da segurança em redes.
- Explorar os principais protocolos de comunicação segura.
- Identificar vulnerabilidades comuns e como mitigá-las.
- Realizar atividades práticas de análise de tráfego e protocolos seguros.

Garantindo a Segurança dos Dados em Redes Wi-Fi Públicas



Pergunta Inicial: *"Quando você se conecta ao Wi-Fi de um café, seus dados estão seguros?"*

Conceitos Fundamentais:

- Proteção de informações trafegadas na rede.
- Identificação de ameaças comuns (ataques MITM, spoofing, sniffing).
- Importância do uso de protocolos seguros.

Exemplo: Caso real de interceptação de dados em redes públicas.

Protocolos mais utilizados:

- **HTTPS**: Segurança em navegação web.
- **TLS/SSL**: Criptografia em comunicação cliente-servidor.
- **VPN**: Criação de canais seguros sobre redes públicas.
- **IPSec**: Segurança em redes privadas virtuais.
- **SSH**: Comunicação segura entre sistemas remotos.

Discussão: *"Por que alguns sites ainda utilizam HTTP e quais são os riscos?"*

Objetivo: Demonstrar como um atacante pode capturar informações em redes não seguras.

Passos:

- Utilização do Wireshark para capturar pacotes em uma rede simulada.
- Análise do tráfego HTTP e comparação com HTTPS.
- Identificação de dados sensíveis trafegados sem criptografia.

Pergunta: *"Quais dados poderiam ser roubados se você acessasse um site sem HTTPS?"*

Motivação:

- Proteger dados ao utilizar redes públicas.
- Garantir anonimato na navegação.

Atividade:

- Explicação rápida sobre como configurar uma VPN gratuita.
- Teste de conexão e análise do tráfego com e sem VPN.

Pergunta: *"Como uma VPN pode proteger seus dados ao acessar redes públicas?"*

Ataques Comuns:

- Man-in-the-Middle (MITM).
- Ataques de DNS Spoofing.
- Sniffing e interceptação de pacotes.

Como se proteger?

- Sempre usar conexões HTTPS.
- Utilizar redes VPN em conexões públicas.
- Configurar firewalls e IDS/IPS em redes empresariais.

Discussão: *"Como um ataque MITM poderia comprometer seus dados bancários?"*

Desafio:

- Um grupo de alunos tentará capturar pacotes de rede sem criptografia (simulado).
- Outro grupo terá que aplicar medidas de defesa (uso de HTTPS, VPN).

Discussão: *"O que aprendemos com essa simulação?"*

Resumo dos principais conceitos:

- Segurança em redes protege a integridade e confidencialidade dos dados.
- Protocolos como HTTPS, TLS, VPN e SSH são essenciais para comunicação segura.
- Ataques como MITM e sniffing podem ser evitados com boas práticas.

Pergunta Final: *"Como você pode aplicar essas práticas na sua vida pessoal e profissional?"*

Pesquisa:

- Descobrir um caso real de ataque MITM e suas consequências.
- Como a empresa afetada poderia ter prevenido o ataque?

- Compreender os principais tipos de ataques cibernéticos.
- Analisar casos reais de ataques e suas consequências.
- Explorar estratégias de mitigação e resposta a incidentes.
- Realizar uma simulação de ataque e defesa.

Pergunta: *"Vocês já ouviram falar de algum grande ataque cibernético? Como ele afetou a empresa ou os usuários?"*

Ataques mais comuns:

- Phishing
- Ransomware
- DDoS (Distributed Denial of Service)
- SQL Injection
- Engenharia Social

Exemplo real: Caso do ataque do ransomware WannaCry em 2017 e seus impactos globais.

1. Reconhecimento:

- Coleta de informações sobre o alvo.
- Uso de ferramentas como Shodan, OSINT.

2. Exploração:

- Uso de vulnerabilidades para obter acesso ao sistema.

3. Execução:

- Implantação de malware, roubo de dados, ou interrupção do serviço.

4. Cobertura de Rastros:

- Exclusão de logs, disfarce de atividades maliciosas.

Discussão: *"Qual dessas etapas é mais crítica para evitar um ataque?"*

Atividade:

- O professor apresentará um e-mail de phishing real e os alunos deverão identificar os sinais de fraude.
- Comparação com um e-mail legítimo para evidenciar as diferenças.

Dicas de proteção:

- Verificar remetente e links.
- Nunca compartilhar credenciais sem verificação.
- Uso de autenticação multifator.

Cenário: Um funcionário recebe um e-mail com um anexo malicioso. Ao abrir, todos os arquivos da empresa são criptografados.

Pergunta: *"O que fazer para evitar esse tipo de ataque?"*

Atividade:

- Dividir a turma em dois grupos:
 - **Grupo 1:** Atacantes - Criam estratégias para enganar a vítima.
 - **Grupo 2:** Defensores - Desenvolvem ações preventivas e de resposta ao incidente.

Prevenção:

- Uso de firewalls e antivírus.
- Atualizações frequentes de sistemas e aplicações.
- Treinamento contínuo para funcionários.

Resposta a Incidentes:

- Isolamento de máquinas infectadas.
- Restauração de backups seguros.
- Investigação e reforço da segurança após o incidente.

Pergunta: *"Qual a primeira ação a ser tomada após identificar um ataque em andamento?"*

Desafio:

- Cada grupo deve criar um plano de resposta para um dos seguintes ataques:
 - Phishing
 - Ransomware
 - DDoS
- Apresentação dos planos e discussão sobre melhorias.

Objetivo: Compreender a importância da preparação para ataques cibernéticos e a necessidade de ações rápidas.

Resumo dos conceitos abordados:

- Principais tipos de ataques cibernéticos.
- Como ocorrem e suas fases.
- Estratégias de mitigação e boas práticas de segurança.

Pergunta Final: *"Se você fosse um analista de segurança, qual a primeira ação que tomaria para proteger uma empresa?"*

Pesquisa:

- Identificar um caso recente de ataque cibernético.
- Analisar como a empresa afetada reagiu e quais medidas foram tomadas para evitar futuros ataques.

- Compreender os principais desafios da segurança em computação em nuvem.
- Explorar boas práticas para proteção de dados e serviços na nuvem.
- Analisar casos reais de ataques e vazamentos de dados em cloud computing.
- Realizar uma atividade prática de configuração de segurança em nuvem.

Pergunta: *"Vocês já armazenaram arquivos em serviços como Google Drive, OneDrive ou AWS? Quais preocupações de segurança vocês têm com esses serviços?"*

Conceitos Fundamentais:

- Computação em nuvem e seus modelos: SaaS, PaaS, IaaS.
- Principais desafios de segurança: controle de acesso, privacidade e conformidade.
- Importância da segurança compartilhada entre provedor e usuário.

Ataques e Vulnerabilidades Comuns:

- Vazamento de dados por má configuração de permissões.
- Ataques de engenharia social e phishing.
- Sequestro de contas e credenciais fracas.
- Ataques de negação de serviço (DDoS).

Caso Real: Vazamento de dados do Facebook (540 milhões de registros expostos devido a configurações inadequadas no AWS S3).

1. Gerenciamento de Acessos:

- Princípio do menor privilégio.
- Uso de autenticação multifator (MFA).

2. Proteção de Dados:

- Criptografia de dados em repouso e em trânsito.
- Configuração de backups automáticos.

3. Monitoramento e Resposta a Incidentes:

- Uso de logs e auditorias em tempo real.
- Implementação de alertas de segurança.

Pergunta: *"Por que a criptografia é essencial para proteger dados na nuvem?"*

Objetivo: Demonstrar como definir permissões corretas para evitar exposição indevida de dados.

Passos:

- Criar um bucket no Amazon S3.
- Aplicar políticas de acesso restritivas.
- Habilitar criptografia de dados e versionamento.
- Monitorar acessos através do AWS CloudTrail.

Discussão: *"O que acontece se um bucket S3 for configurado como público?"*

Tendências e Riscos Emergentes:

- Uso crescente de containers e Kubernetes.
- Segurança de APIs e autenticação federada.
- Conformidade com regulamentações (LGPD, GDPR).

Discussão: *"Como garantir a segurança dos dados em ambientes multi-cloud?"*

Desafio:

- Cada grupo criará um plano de segurança para um serviço fictício baseado em nuvem (ex: um e-commerce ou um sistema de gestão empresarial).
- O plano deve incluir:
 - Estratégias de controle de acesso.
 - Mecanismos de proteção de dados.
 - Monitoramento e resposta a incidentes.
- Apresentação dos planos para a turma e debate sobre melhorias.

Resumo dos principais conceitos:

- Computação em nuvem apresenta desafios e riscos de segurança.
- Adoção de boas práticas como MFA, criptografia e monitoramento é essencial.
- Configuração incorreta de permissões pode levar a vazamentos massivos de dados.

Pergunta Final: *"Se você fosse o responsável pela segurança de um serviço na nuvem, qual seria sua maior preocupação?"*

Pesquisa:

- Investigar um caso real de falha de segurança na nuvem.
- Descrever quais foram as causas e como poderiam ter sido evitadas.

A definir

- Compreender a importância das normas e regulamentações na segurança da informação.
- Explorar os principais frameworks e legislações vigentes.
- Analisar casos reais de violações de conformidade e suas consequências.
- Realizar uma atividade prática de análise de conformidade.

Pergunta Inicial: *"O que acontece quando uma empresa não segue normas de segurança da informação?"*

Importância das Normas:

- Proteção de dados sensíveis.
- Redução de riscos e fraudes.
- Garantia de conformidade legal.

Exemplo Real: Caso do vazamento de dados da Equifax (2017) e as consequências legais.

Alcançando Conformidade de Segurança da Informação



1. LGPD (Lei Geral de Proteção de Dados - Brasil)

- Direitos dos titulares de dados.
- Obrigações das empresas na coleta e tratamento de dados.
- Penalidades por não conformidade.

2. GDPR (Regulamento Geral de Proteção de Dados - União Europeia)

- Regras rígidas para processamento de dados pessoais.
- Multas pesadas por violações.

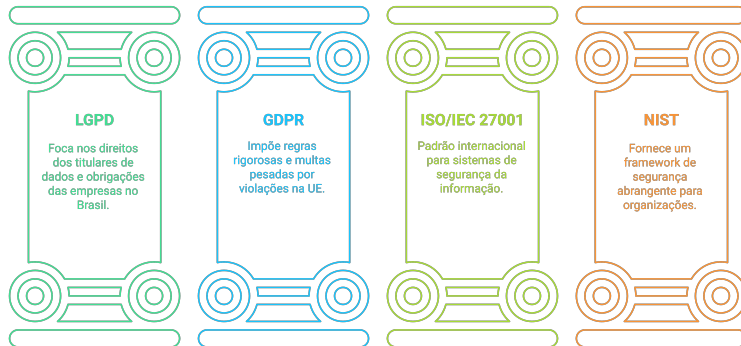
3. ISO/IEC 27001 (Gestão de Segurança da Informação)

- Padrão internacional para implementação de sistemas de segurança da informação.
- Controle de acesso, políticas e auditorias.

4. NIST (National Institute of Standards and Technology)

- Framework de segurança para empresas e governos.
- Definição de práticas e diretrizes de proteção.

Estrutura de Conformidade e Segurança da Informação Global



Exemplo 1: Multa do Facebook por violação de privacidade (US\$ 5 bilhões)

- Falha na proteção de dados de usuários.
- Impacto na confiança dos consumidores.

Exemplo 2: Caso Marriott (500 milhões de dados vazados)

- Falha na detecção de acessos não autorizados.
- Consequências financeiras e reputacionais.

Discussão: *"O que essas empresas poderiam ter feito para evitar esses problemas?"*

Objetivo: Avaliar se uma empresa fictícia está em conformidade com a LGPD e ISO 27001.

Passos:

- O professor apresentará um estudo de caso com práticas inseguras.
- Os alunos devem identificar os problemas de conformidade.
- Propor soluções para adequação às normas.

Discussão: *"Qual norma é mais crítica para uma empresa que processa dados financeiros?"*

1. Implementação de Políticas de Segurança

- Definição clara de diretrizes de proteção de dados.

2. Auditorias e Monitoramento Contínuo

- Revisões periódicas para identificar falhas de segurança.

3. Treinamento de Funcionários

- Conscientização sobre boas práticas e riscos.

Desafio:

- Os alunos serão divididos em dois grupos:
 - **Grupo 1:** Auditores de segurança.
 - **Grupo 2:** Empresa simulada.
- O grupo de auditores identificará problemas de conformidade na empresa fictícia.
- O grupo da empresa apresentará soluções para adequação.

Resumo dos pontos abordados:

- Normas e regulamentações garantem proteção e conformidade.
- LGPD e GDPR são essenciais para privacidade de dados.
- ISO 27001 e NIST fornecem diretrizes técnicas de segurança.
- Violações de normas resultam em impactos financeiros e reputacionais.

Pergunta Final: *"Se você fosse responsável pela segurança de uma empresa, quais normas aplicaria primeiro?"*

Pesquisa:

- Investigar um caso real de multa aplicada por não conformidade com LGPD ou GDPR.
- Explicar as razões da penalização e como a empresa poderia ter evitado a infração.

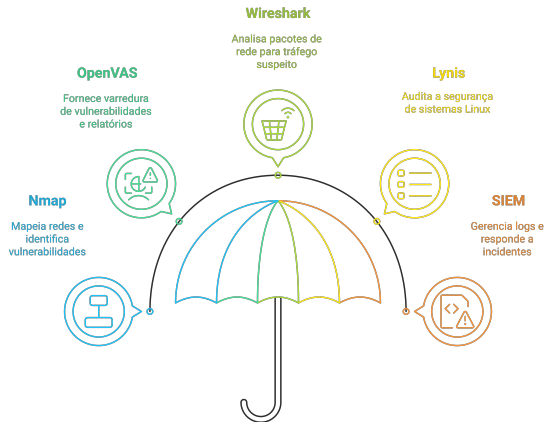
- Compreender a importância da auditoria de segurança digital.
- Explorar ferramentas utilizadas para auditoria e conformidade.
- Analisar casos reais de auditorias de segurança.
- Realizar uma atividade prática de auditoria com ferramentas de mercado.

Pergunta Inicial: *"Como uma empresa pode garantir que seus sistemas estão protegidos contra ataques?"*

Conceitos Fundamentais:

- Auditoria de segurança é um processo sistemático de avaliação de sistemas, redes e políticas organizacionais.
- Garantia de conformidade com normas e regulamentações como LGPD, ISO 27001 e NIST.
- Importância da auditoria na prevenção de ataques e vazamentos de dados.

Ferramentas de Auditoria de Segurança Essenciais



Caso 1: Falha de Auditoria na Equifax (2017)

- Falha em aplicar patches de segurança resultou no vazamento de dados de 147 milhões de pessoas.
- Auditoria falhou em identificar servidores desatualizados.

Caso 2: Ataque à SolarWinds (2020)

- Ataque sofisticado de supply chain.
- Falta de monitoramento permitiu que hackers permanecessem dentro da rede por meses.

Discussão: *"Como auditorias de segurança poderiam ter evitado esses incidentes?"*

Objetivo: Demonstrar o uso do Nmap para auditoria de segurança de redes.

Passos:

- Instalar e configurar o Nmap.
- Executar varredura básica em uma rede simulada.
- Interpretar os resultados e identificar vulnerabilidades.

Comandos Básicos:

- `nmap -sV [endereço-alvo]` → Identificação de serviços ativos.
- `nmap -O [endereço-alvo]` → Detecção do sistema operacional.
- `nmap -script vuln [endereço-alvo]` → Busca por vulnerabilidades conhecidas.

Discussão: *"O que podemos fazer para corrigir as vulnerabilidades encontradas?"*

1. Importância do Monitoramento Contínuo

- Prevenção de incidentes em tempo real.
- Uso de dashboards para acompanhamento de ameaças.

2. Gestão de Riscos

- Identificação de ativos críticos.
- Avaliação de impacto e probabilidade de ataques.

3. Ferramentas para Monitoramento

- SIEM para análise de logs e eventos.
- Firewalls e IDS para proteção ativa.

Pergunta: *"Quais desafios existem na implementação de um sistema de monitoramento eficaz?"*

Desafio:

- Os alunos devem criar um plano de auditoria de segurança para uma empresa fictícia.
- O plano deve incluir:
 - Ferramentas a serem utilizadas.
 - Metodologia de análise de vulnerabilidades.
 - Medidas corretivas para falhas identificadas.
- Cada grupo apresentará suas conclusões e estratégias para auditoria.

Resumo dos principais conceitos:

- Auditoria de segurança é essencial para proteção contra ameaças cibernéticas.
- Ferramentas como Nmap, Wireshark e SIEM ajudam na identificação de vulnerabilidades.
- Casos reais mostram a importância de auditorias regulares e conformidade com normas.
- Monitoramento contínuo e gestão de riscos são fundamentais para a defesa cibernética.

Pergunta Final: *"Se você fosse responsável pela segurança de TI de uma empresa, quais ferramentas de auditoria usaria?"*

Pesquisa:

- Escolher uma ferramenta de auditoria e elaborar um resumo sobre suas funcionalidades.
- Explicar como essa ferramenta pode ser utilizada na prática para melhorar a segurança de uma organização.

- Compreender a importância das políticas de segurança da informação.
- Explorar as etapas do desenvolvimento e implementação de uma política de segurança.
- Analisar casos reais de falhas em políticas de segurança.
- Elaborar uma política de segurança para um ambiente empresarial fictício.

Pergunta Inicial: *"O que pode acontecer se uma empresa não tiver uma política de segurança bem definida?"*

Importância:

- Protege ativos digitais e dados sensíveis.
- Define diretrizes e responsabilidades dos funcionários.
- Reduz riscos de ataques e vazamentos de dados.
- Garante conformidade com normas como LGPD, GDPR e ISO 27001.

Exemplo Real: Caso do vazamento de dados da Uber (2016) devido à falta de controle adequado de credenciais de acesso.

Importância Crucial das Políticas de Segurança da Informação

Conformidade com Normas

Garante aderência a regulamentos e padrões de segurança.

Proteção de Ativos Digitais

Garante que os recursos digitais estejam seguros contra acessos não autorizados e ameaças.



Redução de Riscos

Minimiza a probabilidade de ataques e vazamentos de dados.

Diretrizes e Responsabilidades

Estabelece regras claras e atribui funções para manter a segurança.

1. Controle de Acesso

- Definição de permissões e níveis de acesso.
- Implementação de autenticação multifator (MFA).

2. Proteção de Dados

- Uso de criptografia para dados sensíveis.
- Backups periódicos e controle de versionamento.

3. Gestão de Riscos e Incidentes

- Estratégias de resposta a incidentes de segurança.
- Monitoramento contínuo de ameaças.

4. Treinamento e Conscientização

- Capacitação dos funcionários sobre segurança digital.
- Simulações de ataques para testar respostas.

Pergunta: *"Qual desses componentes vocês acham mais importante para uma empresa?"*

Objetivo: Desenvolver uma política de segurança para uma empresa fictícia.

Passos:

- Dividir os alunos em grupos.
- Cada grupo escolherá um setor empresarial (ex: banco, hospital, e-commerce).
- Criar diretrizes para controle de acesso, proteção de dados e gestão de riscos.
- Apresentar as políticas desenvolvidas para a turma.

Discussão: *"Quais desafios vocês encontraram ao criar a política de segurança?"*

Caso de Estudo: Vazamento de Credenciais em Ambientes Corporativos

Situação:

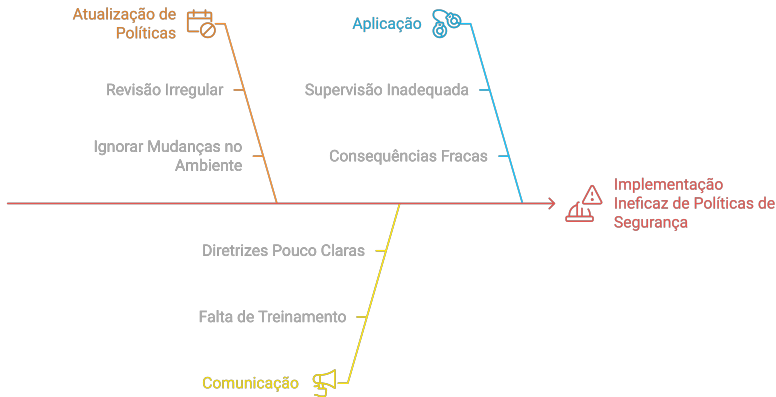
- Um funcionário compartilhou sua senha com outro colaborador.
- Um hacker explorou essa brecha e acessou informações confidenciais.

Pergunta: *"Como uma política de segurança bem definida poderia ter evitado esse incidente?"*

Solução:

- Implementação de autenticação multifator (MFA).
- Restrição de acessos por tempo e dispositivo.
- Monitoramento contínuo de login suspeito.

Causas Comuns de Falhas nas Políticas de Segurança



- ❶ Falta de Atualização
- ❷ Comunicação Ineficiente
- ❸ Falha na Fiscalização

Pergunta: *"Qual desses erros vocês acham mais crítico para uma empresa?"*

Desafio:

- Os alunos atuarão como auditores de segurança.
- O professor apresentará um cenário de uma empresa fictícia com falhas na política de segurança.
- Os alunos devem identificar problemas e sugerir melhorias.
- Cada grupo apresentará um relatório com as mudanças necessárias.

Resumo dos pontos abordados:

- Políticas de segurança são fundamentais para proteção dos ativos digitais.
- Controle de acesso, proteção de dados e resposta a incidentes são pilares essenciais.
- Erros comuns incluem falta de atualização e comunicação ineficiente.
- A auditoria de segurança ajuda a identificar e corrigir falhas.

Pergunta Final: *"Se vocês fossem responsáveis pela segurança de uma empresa, qual seria sua primeira ação?"*

Pesquisa:

- Escolher uma grande empresa e investigar sua política de segurança.
- Identificar falhas já registradas e sugerir melhorias.

- Demonstrar como ocorrem ataques cibernéticos na prática.
- Apresentar estratégias eficazes de resposta a incidentes.
- Simular um ataque e analisar suas consequências.
- Desenvolver um plano de mitigação e recuperação pós-incidente.

Pergunta Inicial: *"Vocês já ouviram falar de algum ataque cibernético famoso? Como ele impactou a empresa ou os usuários?"*

Conceitos Fundamentais:

- O que são ataques cibernéticos e por que ocorrem.
- Principais tipos de ataques: phishing, ransomware, DDoS, SQL Injection.
- Impacto dos ataques na segurança da informação.

Exemplo Real: Caso do ransomware WannaCry (2017) e seus impactos globais.

1. Reconhecimento:

- Coleta de informações sobre o alvo.
- Uso de técnicas como OSINT (Open-Source Intelligence).

2. Exploração:

- Identificação e exploração de vulnerabilidades.

3. Execução do Ataque:

- Implantação de malware, roubo de dados, ou interrupção de serviço.

4. Cobertura de Rastros:

- Exclusão de logs e camuflagem das ações do atacante.

Discussão: *"Qual dessas etapas é mais crítica para evitar um ataque bem-sucedido?"*

Atividade:

- O professor enviará um exemplo de e-mail de phishing aos alunos.
- Os alunos devem identificar os sinais de fraude.
- Comparação com um e-mail legítimo para evidenciar as diferenças.

Dicas de Proteção:

- Verificar remetente e links antes de clicar.
- Nunca compartilhar credenciais sem verificação.
- Uso de autenticação multifator (MFA).

Cenário: Um funcionário recebe um e-mail com um anexo malicioso. Ao abrir, todos os arquivos da empresa são criptografados.

Pergunta: *"O que fazer para evitar esse tipo de ataque?"*

Atividade:

- Dividir a turma em dois grupos:
 - **Grupo 1:** Atacantes - Criam estratégias para enganar a vítima.
 - **Grupo 2:** Defensores - Desenvolvem ações preventivas e de resposta ao incidente.

Passos Essenciais na Resposta a Incidentes:

- Identificação do incidente.
- Contenção para evitar propagação.
- Erradicação da ameaça.
- Recuperação dos sistemas afetados.
- Análise pós-incidente e melhorias na segurança.

Discussão: *"Qual a primeira ação ao identificar um ataque em andamento?"*

Desafio:

- Cada grupo deve criar um plano de resposta para um dos seguintes ataques:
 - Phishing.
 - Ransomware.
 - DDoS.
- Apresentação dos planos e discussão sobre melhorias.

Resumo dos conceitos abordados:

- Principais tipos de ataques cibernéticos e suas fases.
- Estratégias eficazes de resposta a incidentes.
- Como proteger uma organização contra ataques.

Pergunta Final: *"Se você fosse um analista de segurança, qual a primeira ação tomaria para proteger uma empresa?"*

Pesquisa:

- Identificar um caso real de ataque cibernético.
- Analisar como a empresa afetada reagiu e quais medidas foram tomadas para evitar futuros ataques.

- Compreender os princípios da investigação forense digital.
- Explorar as principais ferramentas utilizadas na análise forense.
- Simular um caso prático de coleta e análise de evidências digitais.
- Desenvolver um relatório forense detalhado.

Pergunta Inicial: *"O que vocês entendem por investigação forense digital? Como ela pode ser utilizada?"* **Conceitos Fundamentais:**

- Definição de forense digital e sua aplicação na cibersegurança.
- Importância da coleta e preservação de evidências digitais.
- Uso de técnicas para análise e rastreamento de atividades suspeitas.

Exemplo Real: Investigação do ataque ao sistema da Sony (2014) e como a análise forense ajudou a identificar os responsáveis.

Fases da Investigação Forense Digital



1. Identificação e Preservação:

- Isolamento da cena do crime digital.
- Preservação da integridade das evidências.

2. Coleta de Evidências:

- Cópia forense de discos rígidos e logs.
- Ferramentas para extração segura de dados.

3. Análise e Investigação:

- Identificação de atividades maliciosas.
- Reconstrução da linha do tempo do ataque.

4. Apresentação de Resultados:

- Elaboração de um relatório técnico.
- Testemunho e apresentação jurídica das evidências.

Discussão: *"Qual dessas etapas vocês acham mais desafiadora?"*

1. Autopsy e The Sleuth Kit

- Análise de discos rígidos e recuperação de arquivos deletados.

2. FTK Imager

- Cópia forense de evidências sem alterar os arquivos originais.

3. Wireshark

- Análise de tráfego de rede para identificar atividades suspeitas.

4. Volatility

- Análise de memória RAM para detecção de malwares.

Pergunta: *"Qual dessas ferramentas seria mais útil para investigar um vazamento de dados?"*

Objetivo: Simular um caso de investigação forense para recuperar arquivos deletados e identificar possíveis ataques.

Passos:

- Utilizar o Autopsy para recuperar arquivos de um disco corrompido.
- Analisar logs do sistema para identificar atividades suspeitas.
- Criar uma linha do tempo com os eventos detectados.

Discussão: *"O que podemos concluir a partir das evidências encontradas?"*

1. Volume de Dados

- Processamento de grandes quantidades de logs e arquivos.

2. Criptografia e Ocultação de Dados

- Como decifrar dados protegidos por criptografia forte.

3. Aspectos Legais

- Coleta de evidências sem violar normas de privacidade.

Pergunta: *"Quais são os maiores desafios ao investigar crimes cibernéticos?"*

Desafio:

- Os alunos serão divididos em grupos e cada grupo receberá um caso fictício de crime digital.
- O grupo deverá:
 - Coletar evidências utilizando uma ferramenta de análise forense.
 - Criar um relatório detalhado da investigação.
 - Apresentar suas conclusões para a turma.

Resumo dos principais conceitos:

- A investigação forense digital é essencial para resolver crimes cibernéticos.
- Ferramentas especializadas ajudam a coletar e analisar evidências.
- A apresentação correta das provas é fundamental para a validade legal da investigação.

Pergunta Final: *"Se você fosse um perito forense digital, qual seria sua principal preocupação em um caso real?"*

Pesquisa:

- Escolher um caso real de investigação forense digital.
- Identificar quais técnicas e ferramentas foram usadas para resolver o caso.

- Compreender a importância do monitoramento contínuo na segurança da informação.
- Explorar metodologias para identificação e mitigação de riscos em ambientes corporativos.
- Demonstrar ferramentas e práticas para gestão de riscos.
- Realizar uma atividade prática de análise de riscos e criação de plano de resposta.

Pergunta Inicial: *"Por que o monitoramento contínuo é essencial para a segurança da informação?"* **Conceitos Fundamentais:**

- O monitoramento contínuo permite detectar ameaças em tempo real.
- Ajuda a garantir conformidade com regulamentações e políticas internas.
- Previne ataques cibernéticos antes que causem danos significativos.

Exemplo Real: Caso do ataque SolarWinds (2020) - como a falta de monitoramento permitiu um ataque massivo sem detecção por meses.

Definição: Processo de identificação, análise e mitigação de riscos que podem comprometer a segurança de dados e sistemas. **Etapas da Gestão de Riscos:**

- **Identificação:** Mapeamento de ativos e vulnerabilidades.
- **Análise:** Avaliação da probabilidade e impacto de um ataque.
- **Mitigação:** Implementação de medidas para reduzir riscos.
- **Monitoramento:** Acompanhamento contínuo para detectar novas ameaças.

Pergunta: *"Qual dessas etapas vocês acham mais crítica para evitar falhas de segurança?"*

1. SIEM (Security Information and Event Management)

- Exemplo: Splunk, ELK Stack, IBM QRadar.
- Centraliza logs de diversos sistemas e detecta anomalias.

2. IDS/IPS (Intrusion Detection and Prevention Systems)

- Exemplo: Snort, Suricata.
- Monitoram tráfego de rede e alertam sobre possíveis invasões.

3. Análise de Vulnerabilidades

- Exemplo: Nessus, OpenVAS.
- Identificam falhas de segurança em sistemas antes que sejam exploradas.

Pergunta: *"Se vocês tivessem que escolher apenas uma dessas ferramentas para proteger uma empresa, qual seria e por quê?"*

Objetivo: Simular a identificação e mitigação de riscos em um ambiente corporativo. **Passos:**

- Dividir os alunos em grupos.
- Cada grupo receberá um cenário com um ambiente corporativo fictício.
- Identificar riscos e vulnerabilidades no cenário apresentado.
- Criar um plano de mitigação, sugerindo ferramentas e práticas de segurança.
- Apresentar o plano para a turma e justificar as escolhas.

Discussão: *"Quais foram os principais desafios encontrados ao definir o plano de mitigação?"*

1. Automação de Processos

- Reduz o tempo de resposta a incidentes.
- Exemplos: SIEM, scripts automatizados de detecção de anomalias.

2. Treinamento Contínuo

- Equipes devem ser capacitadas para reconhecer e responder a ameaças.

3. Resiliência e Recuperação

- Implementação de backups e redundância para evitar perda de dados.

Pergunta: *"Quais dessas práticas vocês acham que são mais negligenciadas em empresas?"*

Desafio:

- Os alunos serão divididos em dois grupos:
 - **Grupo 1:** Equipe de segurança da informação.
 - **Grupo 2:** Equipe adversária simulando um ataque.
- O grupo atacante executará ações simuladas como tentativas de phishing ou exploração de vulnerabilidades.
- O grupo defensor utilizará estratégias de monitoramento e mitigação para responder ao ataque.
- Cada grupo apresentará um relatório com os aprendizados e ajustes necessários.

Resumo dos principais conceitos:

- O monitoramento contínuo é essencial para detecção e resposta rápida a incidentes.
- A gestão de riscos permite antecipar ameaças e fortalecer a segurança.
- Ferramentas como SIEM, IDS/IPS e scanners de vulnerabilidades são fundamentais na proteção corporativa.
- Estratégias eficazes de mitigação envolvem automação, treinamento e recuperação de desastres.

Pergunta Final: *"Se vocês fossem responsáveis pela segurança de TI de uma empresa, qual seria a primeira medida que adotariam?"*

Pesquisa:

- Escolher uma empresa real e investigar quais estratégias de monitoramento e gestão de riscos ela adota.
- Comparar com as práticas discutidas em aula e sugerir melhorias.

- Compreender os conceitos e a importância dos pentest.
- Explorar as principais ferramentas e metodologias utilizadas para análise de vulnerabilidades.
- Simular um pentest básico em ambiente controlado.
- Desenvolver estratégias para mitigar vulnerabilidades detectadas.

Pergunta Inicial: *"Vocês acham que um sistema pode ser 100% seguro? Por quê?"* **Conceitos Fundamentais:**

- Pentests são simulações controladas de ataques cibernéticos.
- O objetivo é identificar e corrigir vulnerabilidades antes que sejam exploradas por atacantes reais.
- Diferentes tipos de pentests:
 - **Caixa Branca:** O atacante tem conhecimento total do sistema.
 - **Caixa Cinza:** O atacante tem conhecimento parcial do sistema.
 - **Caixa Preta:** O atacante não tem nenhum conhecimento prévio do sistema.

Exemplo Real: Caso de um banco que contratou hackers éticos para testar sua segurança e evitar fraudes bancárias.

1. Planejamento e Reconhecimento:

- Coleta de informações sobre o alvo (domínios, IPs, serviços expostos).
- Uso de técnicas como OSINT e footprinting.

2. Enumeração e Análise de Vulnerabilidades:

- Identificação de portas abertas e serviços vulneráveis.
- Uso de scanners como Nmap e Nessus.

3. Exploração:

- Tentativa de exploração de falhas para ganhar acesso.
- Utilização de exploits conhecidos (Metasploit, SQL Injection, XSS).

4. Pós-exploração e Relatório:

- Extração de dados e persistência no sistema.
- Documentação das falhas encontradas e sugestões de mitigação.

Pergunta: *"Qual dessas etapas vocês acham mais crítica para garantir um pentest eficaz?"*

1. Nmap

- Scanner de redes para identificar portas abertas e serviços ativos.

2. Nessus

- Ferramenta de varredura de vulnerabilidades.
- Detecta falhas em sistemas operacionais, servidores e aplicações web.

3. Metasploit

- Plataforma para exploração de vulnerabilidades.
- Automatiza ataques contra sistemas vulneráveis.

4. Burp Suite

- Teste de segurança em aplicações web.
- Intercepta requisições HTTP e permite manipular pacotes.

Pergunta: *"Se vocês fossem pentesters, qual ferramenta escolheriam para iniciar um teste?"*

Objetivo: Demonstrar como identificar vulnerabilidades em um ambiente controlado.

Passos:

- Utilizar o **Nmap** para mapear uma rede fictícia.
- Identificar serviços expostos e possíveis vulnerabilidades.
- Analisar os resultados e propor estratégias de mitigação.

Comandos Básicos do Nmap:

- `nmap -sV [endereço-alvo]` → Identifica serviços ativos.
- `nmap -O [endereço-alvo]` → Detecta o sistema operacional.
- `nmap -script vuln [endereço-alvo]` → Busca por vulnerabilidades conhecidas.

Discussão: *"O que podemos fazer para corrigir as vulnerabilidades encontradas?"*

1. Definir Escopo e Permissões

- Evitar testes não autorizados que possam causar danos ao sistema.

2. Seguir Metodologias Reconhecidas

- OWASP, PTES (Penetration Testing Execution Standard).

3. Relatar as Vulnerabilidades Encontradas

- Criar um relatório detalhado com recomendações de mitigação.

Pergunta: *"Quais desafios vocês acham que um pentester pode enfrentar ao testar um sistema?"*

Desafio:

- Dividir os alunos em dois grupos:
 - **Grupo 1:** Equipe de segurança da informação.
 - **Grupo 2:** Equipe ofensiva realizando um pentest.
- O grupo atacante usará ferramentas de varredura e tentará identificar vulnerabilidades em um ambiente simulado.
- O grupo defensor analisará os ataques e proporá soluções para mitigar as vulnerabilidades encontradas.
- Cada grupo apresentará um relatório com os aprendizados e ajustes necessários.

Resumo dos principais conceitos:

- Pentests ajudam a identificar e corrigir vulnerabilidades antes que sejam exploradas.
- O pentest segue uma metodologia estruturada: reconhecimento, enumeração, exploração e relatório.
- Ferramentas como Nmap, Nessus e Metasploit são essenciais para pentesters.
- A mitigação de vulnerabilidades exige ações preventivas e monitoramento contínuo.

Pergunta Final: *"Se vocês fossem responsáveis pela segurança de um sistema, com que frequência realizariam um pentest?"*

Pesquisa:

- Escolher uma empresa real e investigar se já foi alvo de um pentest público.
- Descrever quais vulnerabilidades foram identificadas e como foram corrigidas.

A definir